МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ
Національний технічний університет України
«Київський політехнічний інститут імені Ігоря Сікорського»
Факультет інформатики та обчислювальної техніки
Кафедра інформатики та програмної інженерії

ЗВІТ

з лабораторної роботи № 1
«Побудова моделі загроз програмного застосунку»
з дисципліни «Безпека програмного забезпечення»

Варіант 14

Виконав:
здобувач групи ІП-34
Скачков І. О.

Перевірив:
Курченко О. А.

Київ — 2026

1 МЕТА ТА ЗАВДАННЯ РОБОТИ

Мета роботи — набути практичних навичок систематичного передпроєктного аналізу захищеності програмного застосунку через побудову його моделі загроз, кількісне оцінювання виявлених загроз та обґрунтоване планування контрзаходів.

Завдання роботи:

1) описати активи заданої системи та побудувати діаграму потоків даних (DFD) із позначенням меж довіри;
2) застосувати методологію STRIDE до кожного елемента діаграми й скласти перелік щонайменше з 12 загроз;
3) оцінити кожну загрозу за метрикою CVSS v3.1 наданим калькулятором і визначити щонайменше три загрози високого ризику;
4) побудувати дерево атак для найкритичнішої загрози;
5) сформувати реєстр ризиків із рішенням щодо кожного ризику та переліком контрзаходів;
6) обґрунтувати висновки щодо пріоритетності усунення загроз.

Параметри індивідуального варіанта отримано командою `python -m common.variants 14 --lab 1` з кореня репозиторію курсу (табл. 1.1).

Таблиця 1.1 – Індивідуальне завдання (варіант 14)

Параметр	Значення
Об’єкт моделювання (system)	система електронного документообігу кафедри
Пріоритетна категорія STRIDE (focus_category)	розкриття інформації (Information disclosure)
Мінімум загроз (min_threats)	12
Мінімум загроз високого ризику (min_high_risk)	3 (базова оцінка CVSS ≥ 7,0)

2 ТЕОРЕТИЧНЕ ОБҐРУНТУВАННЯ ПРИЙНЯТИХ РІШЕНЬ

2.1 Вибір меж довіри

Межу довіри проведено всюди, де дані переходять між компонентами з різним рівнем контролю з боку кафедри. Тому, крім очевидної межі «Інтернет — сервер», виділено окремо DMZ зі зворотним проксі, зону застосунку, зону даних, інфраструктуру університету (SSO, пошта — ними кафедра не керує) і зону хмарного провайдера резервних копій. Такий поділ дає змогу побачити потоки, що оминають точку контролю доступу: для СЕД це видача файлів за pre-signed URL (DMZ → зона даних напряму) і проксіювання пошукового API, які й стали джерелом найнебезпечніших загроз.

Пошуковий індекс OpenSearch навмисно показано як окреме сховище, а не як частину застосунку: він містить повний текст документів, тобто є другою копією найціннішого активу і потребує тих самих властивостей захисту, що й файлове сховище.

2.2 STRIDE за елементами

Застосовано варіант STRIDE-per-element: до зовнішніх сутностей — категорії S і R, до процесів — усі шість, до сховищ — T, I, D (і R лише для журналу аудиту), до потоків — T, I, D. Для побудованої діаграми це дає 101 пару «елемент — категорія» (5 сутностей × 2 + 4 процеси × 6 + 4 сховища × 3 + журнал × 4 + 17 потоків × 3). З них відібрано 22 реалістичні для СЕД загрози: пари, для яких не вдалося назвати конкретний механізм атаки, до переліку не потрапили.

2.3 Кількісне оцінювання

Базову оцінку CVSS v3.1 обчислено наданим калькулятором cvss.py. Межею високого ризику вважається оцінка ≥ 7,0. Базова оцінка не враховує, скільки порушників реально можуть скористатися вадою (наприклад, усі 600 здобувачів мають обліковий запис), тому її доповнено матрицею «ймовірність × вплив» 3×3: імовірність оцінено експертно з урахуванням кола порушників і поширеності помилки, вплив — за цінністю зачепленого активу. Область S:C застосовано лише

там, де наслідки виходять за межі повноважень вразливого компонента (XSS у браузері іншого користувача; виконання коду в обробнику з доступом до ключів сховищ).

2.4 Дерево атак і реєстр ризиків

Корінь дерева атак для найкритичнішої загрози є вузлом OR: щоб захистити мету, захисник має перекрити всі гілки, тоді як порушнику досить однієї. Тому під час вибору контрзаходів пріоритет надано заходам, що діють на рівні самого активу (мінімізація даних в індексі) і перекривають кілька гілок одночасно. У реєстрі для кожної загрози обрано одну стратегію (усунути, зменшити, передати, прийняти), а залишковий ризик обчислено тим самим калькулятором для вектора після впровадження контрзаходу.

3 ОПИС РОЗРОБЛЕНОГО РІШЕННЯ

3.1 Структура репозиторію та програмні засоби

Робота виконана в папці SoS репозиторію 7-sem; структура папки повторює репозиторій курсу:

```
SoS/
  common/variants.py          генератор варіантів (з репозиторію курсу)
  lab01_threat_model/
    cvss.py                   калькулятор CVSS v3.1 (з репозиторію курсу)
    scoring.py                перелік загроз, оцінювання, самоперевірка
    templates/                шаблони threat_model.md і dfd.mmd
  звіт_лр1/
    threat_model.md           модель загроз (розділи 1–7)
    dfd.mmd, dfd.png          діаграма потоків даних
    attack_tree.mmd, .png     дерево атак для T-01
    scoring_output.txt        вивід scoring.py
```

Використано Python 3.12, Git, Mermaid (діаграми DFD і дерева атак описано текстом і відрендерено в PNG утилітою mermaid-cli). Опис діаграм у текстовому форматі обрано, щоб діаграми версіонувалися разом із моделлю загроз і змінювалися через звичайні коміти.

3.2 Опис системи та активи

Система електронного документообігу (СЕД) кафедри зберігає й веде маршрутами погодження внутрішні документи: заяви й подання здобувачів,

проєкти наказів щодо здобувачів, екзаменаційні відомості, протоколи засідань кафедри, кадрові документи викладачів, рецензії. Документ проходить маршрут «створення → погодження → підписання → публікація адресатам». Користувачі: працівники кафедри (≈ 40 осіб: викладачі, секретар, завідувач), здобувачі (≈ 600 осіб), адміністратор СЕД. Зовнішні служби: єдиний вхід університету (SSO, OpenID Connect), поштовий сервер університету, хмарне сховище резервних копій. Система вигадана, усі дані синтетичні.

Технічно СЕД складається зі зворотного проксі Nginx (P1), застосунку з REST API (P2), фонового обробника (P3), завдання резервного копіювання (P4), БД PostgreSQL (D1), файлового сховища MinIO (D2), пошукового індексу OpenSearch (D3), журналу аудиту (D4) і резервних копій у хмарі (D5). Виявлені активи наведено в табл. 3.1.

Таблиця 3.1 – Активи системи та їхня цінність за властивостями К/Ц/Д

ID	Актив	Тип	Цінність (К/Ц/Д)
A1	Документи обмеженого доступу: накази щодо здобувачів, відомості, протоколи засідань, кадрові документи, рецензії	інформаційний (вміст документів)	В/В/С
A2	Персональні дані здобувачів і працівників: ПІБ, контакти, оцінки, РНОКПП у кадрових документах	інформаційний (персональні дані)	В/В/С
A3	Облікові записи, сесійні cookie, ID-токени SSO	автентифікаційні дані	В/В/С
A4	Маршрути погодження, резолюції, позначки підписання документів	юридично значущі дані	С/В/С
A5	Повнотекстовий пошуковий індекс (похідна копія вмісту A1)	інформаційний (похідний)	В/С/Н
A6	Журнал аудиту та журнали застосунку	службові дані	С/С/Н
A7	Секрети: пароль до БД, ключі доступу MinIO, клієнтський секрет OIDC, ключ підпису сесій	криптографічні/службові ключі	В/В/С
A8	Резервні копії БД і сховища файлів	інформаційний (копія A1, A2)	В/В/С
A9	Безперервність послуги (подання заяв і погодження наказів у встановлені строки)	послуга	Н/Н/С

Шкала: В — висока, С — середня, Н — низька. Високу конфіденційність мають A1, A2, A3, A5, A7, A8; високу цілісність — A1–A4, A7, A8.

3.3 Діаграма потоків даних

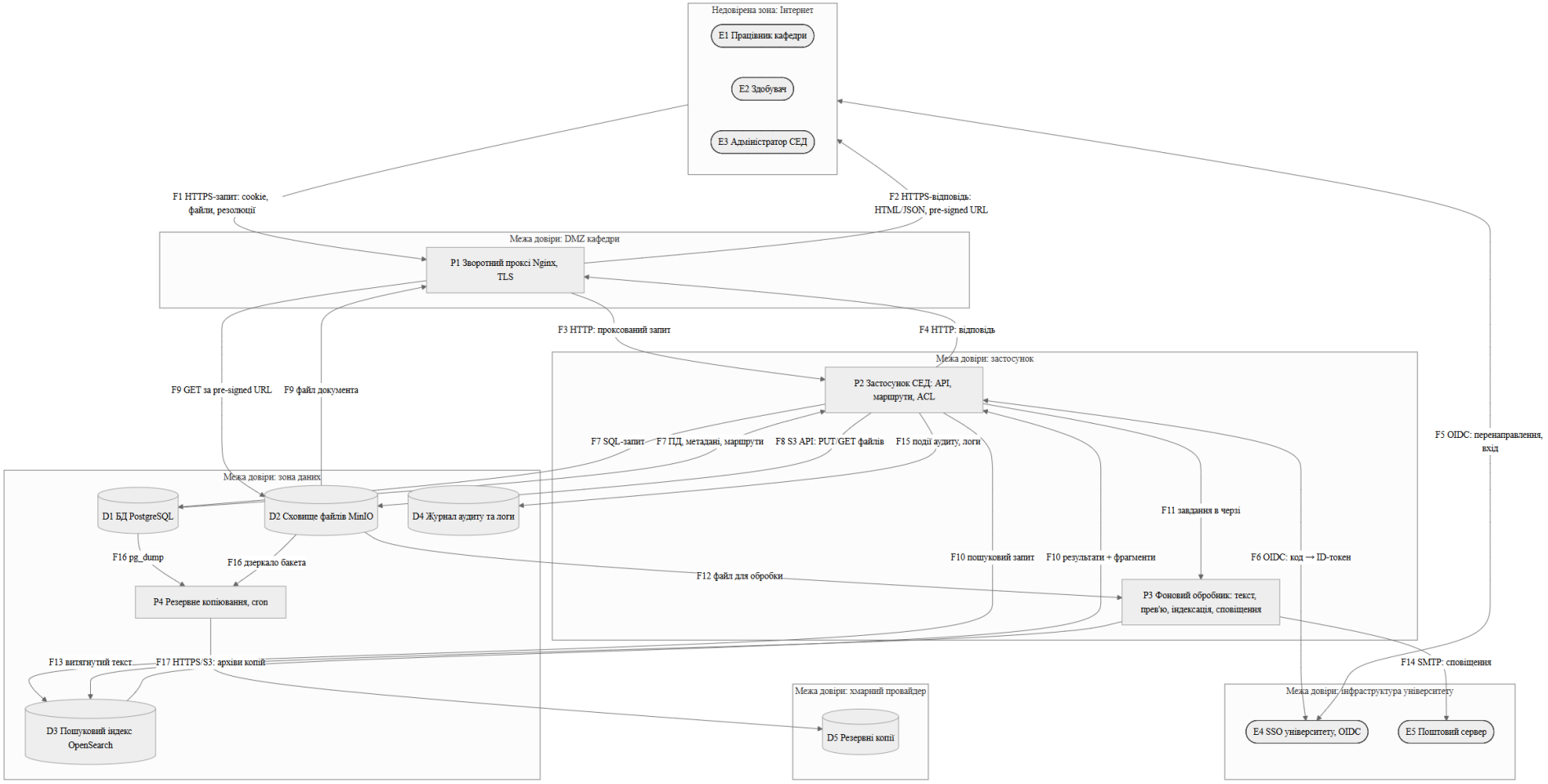


Рисунок 3.1 – Діаграма потоків даних СЕД кафедри з межами довіри (джерело — dfd.mmd)

Діаграма (рис. 3.1) містить усі чотири типи елементів: зовнішні сутності E1–E5 (овали), процеси P1–P4 (прямокутники), сховища D1–D5 (циліндри) і 17 підписаних потоків F1–F17, згрупованих у шість зон довіри (табл. 3.2).

Таблиця 3.2 – Елементи діаграми потоків даних

ID	Тип елемента DFD	Опис	Зона довіри
E1, E2, E3	зовнішня сутність	працівник, здобувач, адміністратор (браузер)	недовірена (Інтернет)
E4	зовнішня сутність	SSO університету (OIDC-провайдер)	інфраструктура університету
E5	зовнішня сутність	поштовий сервер університету	інфраструктура університету
P1	процес	зворотний проксі Nginx, завершення TLS	DMZ кафедри
P2	процес	застосунок СЕД: REST API, маршрути погодження, перевірка прав (ACL)	застосунок
P3	процес	фоновий обробник: витяг тексту, прев'ю, індексація, сповіщення	застосунок
P4	процес	завдання резервного копіювання (cron)	зона даних
D1	сховище	БД PostgreSQL: користувачі, ролі, метадані, маршрути	зона даних
D2	сховище	MinIO: файли документів і прев'ю	зона даних
D3	сховище	OpenSearch: повний текст документів для пошуку	зона даних
D4	сховище	журнал аудиту та журнали застосунку	зона даних
D5	сховище	резервні копії в хмарі	хмарний провайдер

3.4 Програмна реалізація оцінювання

Оцінювання автоматизовано файлом scoring.py, який імпортує функцію base_score з наданого калькулятора. Перелік загроз — єдине джерело даних: кожен запис містить елемент DFD, категорію STRIDE, вектор CVSS до і після контрзаходу та експертні ймовірність і вплив:

```
# (id, елемент DFD, STRIDE, назва, вектор, залишковий вектор,
#  ймовірність, вплив)
THREATS = [
    ("T-01", "D3", "I",
     "Відкритий REST API пошукового індексу з повними текстами",
     "AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L",
     "AV:A/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N", "В", "В"),
    ...
]
```

Матриця «ймовірність × вплив» переводить оцінки H/C/B у бали 1–3 і класифікує їх добуток; ранг загрози визначається спершу базовою оцінкою, а за рівних оцінок — добутком матриці:

```
def matrix_level(likelihood: str, impact: str) -> str:
    product = LEVEL_POINTS[likelihood] * LEVEL_POINTS[impact]
    if product >= 6:
        return "високий"
    if product >= 3:
        return "середній"
    return "низький"

order = sorted(rows, key=lambda r: (
    -r["score"],
    -LEVEL_POINTS[r["lik"]] * LEVEL_POINTS[r["imp"]],
    r["id"]))
```

Наприкінці скрипт перевіряє кількісні вимоги варіанта (не менше 12 загроз і 3 загроз високого ризику, щонайменше 3 категорії STRIDE, переважання пріоритетної категорії, залишкова оцінка не вища за вихідну, контрольний вектор дає 9,8) і завершується з кодом 1, якщо якусь вимогу порушено. Параметр `--md` друкує таблицю розділу 4 моделі загроз у форматі Markdown. Повний лістинг — у додатку Г.

4 РЕЗУЛЬТАТИ

4.1 Загрози за STRIDE

Підрозділи 4.1–4.4 відповідають розділам 3–6 файла threat_model.md. Для кожного елемента DFD перебрано характерні категорії STRIDE; перелік із 22 загроз наведено в табл. 4.1 (розподіл за категоріями: I — 12, S, T, R, D, E — по 2).

Таблиця 4.1 – Загрози за STRIDE

№	Елемент / потік	Кат.	Опис загрози	Порушувана властивість
T-01	D3 (через P1)	I	REST API OpenSearch працює без автентифікації (security plugin вимкнено, «бо індекс внутрішній»), а в конфігурації P1 є `location /search-api/`, що проксіює запити до D3. Зовнішній зловмисник без облікового запису вивантажує повні тексти всіх проіндексованих документів (CWE-306, CWE-668)	конфіденційність
T-02	P2	I	IDOR: `GET /api/documents/{id}/file` перевіряє лише наявність сесії, але не право на конкретний документ; ідентифікатори послідовні. Будь-який здобувач перебором `id` завантажує чужі накази, відомості, кадрові документи (CWE-639)	конфіденційність

№	Елемент / потік	Кат.	Опис загрози	Порушувана властивість
T-03	P2	I	Пошук фільтрує за ACL лише список результатів, але повертає загальну кількість збігів і фрагменти (highlight) недоступних документів. Запит «відрахування Прізвище» розкриває факт і зміст наказу (CWE-200, бічний канал)	конфіденційність
T-04	D2	I	Для швидкого прев'ю бакету `documents` у MinIO задано анонімну політику `download`, а S3-ендпойнт опубліковано через P1 для pre-signed URL. Ключі об'єктів передбачувані (`2026/{id}.pdf`), тож файли доступні без автентифікації (CWE-732)	конфіденційність
T-05	F2	I	Pre-signed URL мають строк дії 7 діб і потрапляють у листи, історію браузера, заголовок `Referer` під час переходу на зовнішні посилання з прев'ю, пересилаються між здобувачами — будь-хто з посиланням завантажує документ (CWE-598)	конфіденційність
T-06	F14	I	Лист-сповіщення містить тему, перші абзаци документа й вкладення; надсилається на особисті скриньки здобувачів, ретрансляція між MTA допускає відкат до нешифрованого SMTP (CWE-319)	конфіденційність
T-07	F3/F4	I	P1 завершує TLS, далі трафік до P2 іде відкритим HTTP у спільному VLAN з іншими серверами кафедри; зловмисник у суміжному сегменті перехоплює cookie сесій і вміст документів (CWE-319)	конфіденційність
T-08	P2	I	Увімкнений режим налагодження: сторінка помилки показує трасування стека, SQL-запит і змінні оточення, зокрема ключі MinIO та OpenSearch (CWE-209, CWE-215)	конфіденційність
T-09	P3	I	Під час публікації документ передається адресату як є: у DOCX лишаються автор, історія рецензування й видалені фрагменти, у PDF «зафарбовані» прямокутниками ПІБ залишаються текстовим шаром (CWE-212)	конфіденційність
T-10	D4	I	Журнали застосунку записують заголовки запитів (cookie сесій), коди OIDC і тіла запитів із ПІБ та текстом резолюцій; журнали читають адміністратори ОС і система моніторингу (CWE-532)	конфіденційність
T-11	D5	I	Резервні копії (дамп D1, дзеркало D2, знімки D3) вивантажуються в хмару незашифрованими; ключ доступу до бакета записано у cron-скрипті P4. Компрометація ключа або облікового запису провайдера розкриває всі дані (CWE-311)	конфіденційність
T-12	D1	I	Застосунок підключається до PostgreSQL як суперкористувач, пароль у відкритому вигляді зберігається в `.env` і в репозиторії розгортання; хто отримав доступ до репозиторію чи сервера, читає і змінює всю БД (CWE-250, CWE-798)	конфіденційність
T-13	E1	S	Збережений XSS у полі «коментар до погодження»: скрипт виконується в браузері завідувача, cookie сесії без `HttpOnly` відправляється зловмиснику, який далі діє від імені завідувача (CWE-79, CWE-1004)	автентичність
T-14	E4	S	P2 не перевіряє `aud` та `nonce` ID-токена: токен, виданий SSO іншому застосунку університету, яким керує зловмисник, приймається СЕД — вхід від імені користувача, що автентифікувався в тому застосунку (CWE-287)	автентичність
T-15	D2	T	Файл уже підписаного документа можна замінити в MinIO (версіонування вимкнено, хеш файлу не прив'язано до підпису в D1); інсайдер із доступом до сховища підмінює текст наказу (CWE-345)	цілісність
T-16	P2	T	CSRF: `POST /api/routes/{id}/approve` не має CSRF-токена, cookie має `SameSite=None`; працівник, відкривши сторонню сторінку, непомітно погоджує документ (CWE-352)	цілісність

№	Елемент / потік	Кат.	Опис загрози	Порушувана властивість
T-17	E1	R	Погодження — проста кнопка без електронного підпису; у журналі лише `user_id` і час сервера. Працівник заперечує, що погоджував наказ (CWE-778)	неспростовність
T-18	D4	R	Журнал аудиту — звичайна таблиця в D1, адміністратор має права UPDATE/DELETE; перегляди й завантаження документів не журналюються зовсім, тож витік неможливо розслідувати (CWE-117, CWE-778)	неспростовність
T-19	P3	D	Завантаження «бомб» (DOCX як zip-бомба, PDF на тисячі сторінок) виснажує пам'ять і процесор обробника, черга прев'ю та сповіщень зупиняється (CWE-400, CWE-409)	доступність
T-20	F1	D	Масові запити в пікові періоди (завершення сесії, атестація) або важкі пошукові запити з шаблонами `*` перевантажують P1/P2 (CWE-770)	доступність
T-21	P3	E	Конвертер (LibreOffice headless, Ghostscript) обробляє файли користувачів з правами процесу, якому доступні ключі MinIO та OpenSearch; спеціально сформований документ дає виконання коду та вихід за межі обробника (CWE-94, CWE-250)	авторизація
T-22	P2	E	Роль «секретар» може призначати будь-які ролі, зокрема «завідувач»; немає матриці делегування, тож секретар надає собі чи іншим права підписання й доступ до кадрових документів (CWE-269)	авторизація

4.2 Оцінювання за CVSS

Скрипт `python scoring.py` (каталог lab01_threat_model) обчислив оцінки всіх 22 загроз і пройшов усі самоперевірки; повний вивід наведено в додатку Б. Таблиця оцінювання з імовірністю, впливом і рангом (табл. 4.2) отримана командою `python scoring.py --md`. Жирним виділено загрози високого ризику.

Таблиця 4.2 – Оцінювання загроз (CVSS / матриця)

№	Вектор CVSS:3.1/…	Базова оцінка	Імов.	Вплив	Ранг ризику
T-01	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L`	**8.6** (високий)	В	В	1 — високий
T-02	`AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`	6.5 (середній)	В	В	6 — високий
T-03	`AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N`	4.3 (середній)	С	С	20 — середній
T-04	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`	**7.5** (високий)	С	В	4 — високий
T-05	`AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N`	5.3 (середній)	С	С	14 — середній
T-06	`AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`	5.9 (середній)	С	С	11 — середній
T-07	`AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N`	5.9 (середній)	Н	В	12 — середній
T-08	`AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`	5.3 (середній)	В	Н	15 — середній
T-09	`AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N`	4.3 (середній)	С	С	21 — середній
T-10	`AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N`	4.4 (середній)	Н	С	19 — низький
T-11	`AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`	5.9 (середній)	Н	В	13 — середній
T-12	`AV:A/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N`	6.4 (середній)	Н	В	10 — середній
T-13	`AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N`	**7.6** (високий)	С	В	3 — високий
T-14	`AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N`	6.8 (середній)	Н	В	5 — середній
T-15	`AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N`	4.9 (середній)	Н	В	17 — середній

№	Вектор CVSS:3.1/…	Базова оцінка	Імов.	Вплив	Ранг ризику
T-16	AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N	6.5 (середній)	C	C	7 — середній
T-17	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N	4.3 (середній)	C	C	22 — середній
T-18	AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N	4.9 (середній)	H	C	18 — низький
T-19	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H	6.5 (середній)	C	C	8 — середній
T-20	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L	5.3 (середній)	C	H	16 — низький
T-21	AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H	**8.5** (високий)	C	B	2 — високий
T-22	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N	6.5 (середній)	H	B	9 — середній

Загроз високого ризику (CVSS ≥ 7,0) чотири: T-01 (8,6), T-21 (8,5), T-13 (7,6), T-04 (7,5), що перевищує вимогу min_high_risk = 3. T-02 має оцінку 6,5, але за матрицею — високий ризик (імовірність B: усі здобувачі мають обліковий запис, ідентифікатори послідовні), тому в реєстрі її опрацьовано разом із високими.

Обґрунтування неочевидних метрик: T-01 — I:L/A:L, бо індекс похідний і відновлюється з D2; T-13 — S:C, бо скрипт із поля P2 виконується в браузері іншого користувача, I:L, бо підписання потребує повторного підтвердження; T-21 — S:C, бо виконання коду в P3 дає ключі сховищ зони даних, AC:H, бо експлойт залежить від версії конвертера; T-12 — AV:A, бо порт PostgreSQL доступний лише з внутрішньої мережі.

Покрокова верифікація калькулятора. Контрольний вектор `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` дає 9,8, як і очікується. Для найкритичнішої загрози T-01 обчислення вручну за формулами (2.1)–(2.3) практикуму:

```
ISS            = 1 − (1 − 0,56)(1 − 0,22)(1 − 0,22) = 1 − 0,2677 = 0,7323
Impact         = 6,42 × 0,7323 = 4,701
Exploitability = 8,22 × 0,85 × 0,77 × 0,85 × 0,85 = 3,887
BaseScore      = Roundup(min(4,701 + 3,887; 10)) = Roundup(8,588) = 8,6
```

Ручний результат збігається з виводом калькулятора (8,6).

4.3 Дерево атак для найкритичнішої загрози

Найкритичніша загроза — T-01 (CVSS 8,6): відкритий REST API пошукового індексу з повними текстами документів. Корінь дерева (рис. 4.1) — її мета; дерево містить вузли OR (корінь, 1.1, 3, 4.1) та AND (гілки 1, 2, 4). Текстове подання дерева наведено в додатку B і в розділі 6 файла threat_model.md.

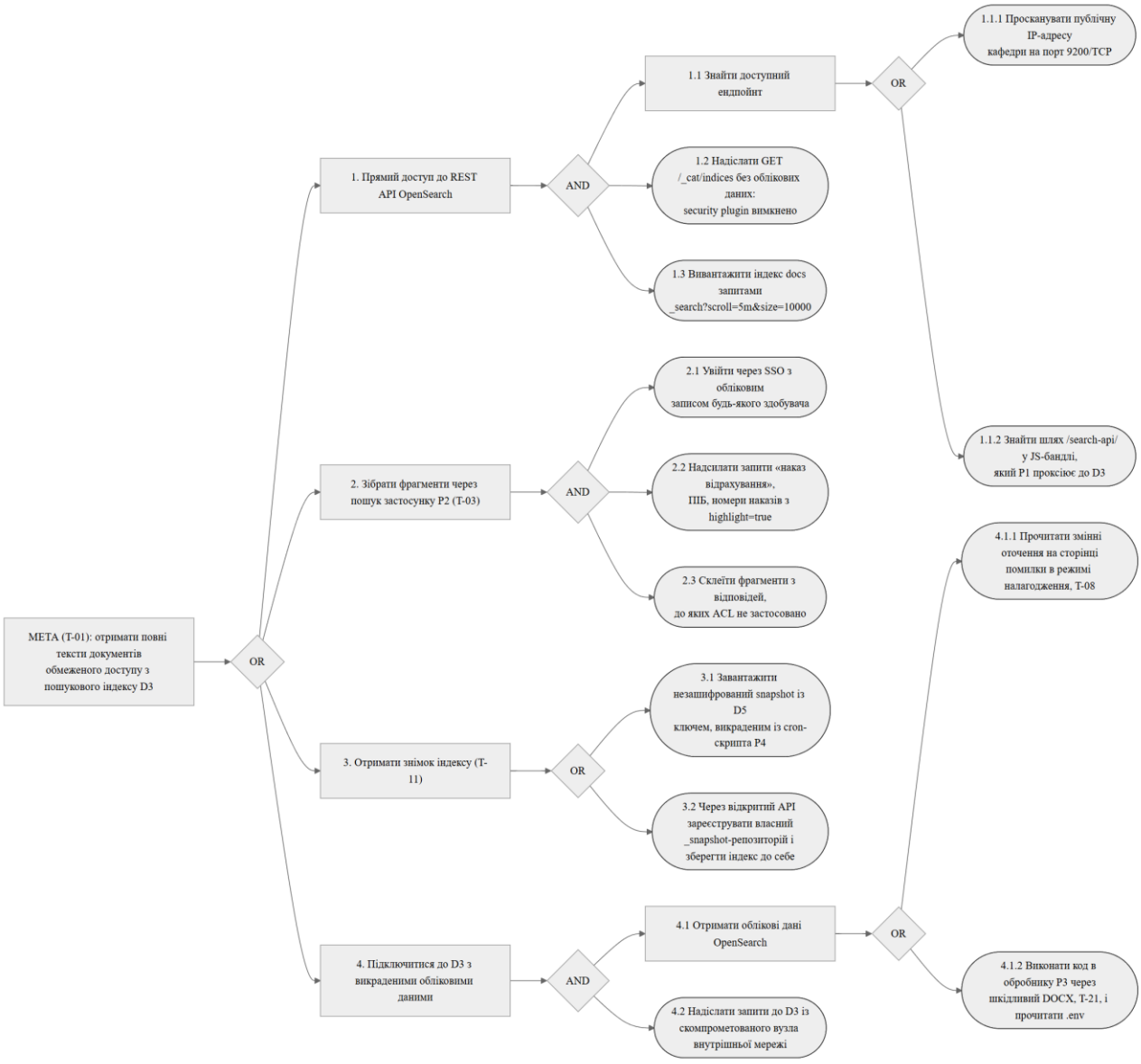


Рисунок 4.1 – Дерево атак для загрози T-01 (джерело — attack_tree.mmd)

Найдешевший для порушника шлях — гілка 1 через лист 1.1.2: шлях до API видно в коді фронтенду, обліковий запис не потрібен, досить трьох HTTP-запитів. Гілка 2 потребує облікового запису й дає лише фрагменти, гілки 3 і 4 — попередньої компрометації інших компонентів. Відповідні шаблони атак: CAPEC-87 (Forceful Browsing) для 1.1.2, CAPEC-300 (Port Scanning) для 1.1.1, CAPEC-54 (Query System for Information) для гілки 2.

4.4 Реєстр ризиків і рішення

Для кожної загрози обрано стратегію оброблення та контрзахід (табл. 4.3). Залишковий ризик — оцінка калькулятора для вектора після впровадження контрзаходу.

Таблиця 4.3 – Реєстр ризиків

№	Ризик	Рішення	Контрзахід	Залишковий ризик
T-01	Масовий витік текстів документів з D3	усунути	Увімкнути security plugin OpenSearch (автентифікація, TLS, ролі тільки для P2/P3); прибрати `location /search-api/` з P1; мережеве правило «D3 приймає з'єднання лише від P2 і P3»; для документів із грифом обмеженого доступу індексувати лише метадані	2.0 (низький)
T-02	IDOR під час завантаження файлів	зменшити	Централізована перевірка права на об'єкт у кожному обробнику (policy enforcement point), ідентифікатори UUIDv4, автотести авторизації для кожного маршруту, журналювання завантажень	3.1 (низький)
T-03	Фрагменти недоступних документів у пошуку	зменшити	ACL-фільтр у самому запиті до D3 (document-level security), а не після нього; без highlight і лічильника для недоступних документів	3.1 (низький)
T-04	Анонімний доступ до бакета MinIO	усунути	Прибрати анонімну політику, заборонити публічні політики бакета; S3-ендпойнт не публікувати через P1, видавати файли через P2 після перевірки прав	2.2 (низький)
T-05	Витік pre-signed URL	зменшити	Строк дії посилання — 5 хв, одноразове завантаження через P2, `Referrer-Policy: no-referrer`, у листах — лише посилання на картку документа в СЕД	3.1 (низький)
T-06	Вміст документів у листах	зменшити	Лист містить лише назву й посилання на СЕД без вкладень і фрагментів; MTA-STS / обов'язковий STARTTLS; надсилання тільки на корпоративні скриньки	3.7 (низький)
T-07	Перехоплення трафіку P1↔P2	зменшити	TLS (mTLS) між P1 і P2, окремий VLAN для СЕД	2.0 (низький)
T-08	Детальні помилки	усунути	Вимкнути режим налагодження у production, типова сторінка помилки з ідентифікатором кореляції, деталі — лише в журнал	3.7 (низький)
T-09	Приховані дані в опублікованих файлах	зменшити	Під час публікації — очищення метаданих (mat2 / exiftool), прийняття всіх виправлень, справжнє редагування PDF (видалення текстового шару)	3.1 (низький)
T-10	Секрети й ПД у журналах	зменшити	Маскування cookie, токенів, кодів OIDC і ПД у логері; доступ до журналів за ролями, строк зберігання 90 днів	1.9 (низький)
T-11	Нешифровані резервні копії у хмарі	передати	Договір із провайдером (SLA, відповідальність за інциденти, розміщення даних) + шифрування копій на боці кафедри (age/GPG) до вивантаження, ключ — окремо від копій, MFA для облікового запису провайдера	2.2 (низький)
T-12	Суперкористувач БД, пароль у `.env`	зменшити	Окремий обліковий запис з мінімальними правами (без DDL, без доступу до D4), секрети — у сховищі секретів, ротація пароля, видалення пароля з історії репозиторію	3.1 (низький)

№	Ризик	Рішення	Контрзахід	Залишковий ризик
Т-13	Викрадення сесії завідувача через XSS	зменшити	Контекстне кодування виводу, Content-Security-Policy без `unsafe-inline`, cookie `HttpOnly; Secure; SameSite=Lax`, повторне підтвердження для підписання	3.7 (низький)
Т-14	Підстановка ID-токена SSO	усунути	Перевірка підпису, `iss`, `aud`, `exp`, `nonce` і `state` сертифікованою бібліотекою OIDC; PKCE	3.1 (низький)
Т-15	Заміна файлу підписаного документа	зменшити	SHA-256 файлу зберігається в D1 разом із підписом і перевіряється під час видачі; версіонування та Object Lock у MinIO	2.2 (низький)
Т-16	CSRF на погодження	усунути	CSRF-токен для всіх змінювальних запитів, `SameSite=Lax`, перевірка `Origin`	3.1 (низький)
Т-17	Заперечення погодження	зменшити	Погодження й підписання кваліфікованим електронним підписом над хешем документа з міткою часу від надавача довірчих послуг	3.1 (низький)
Т-18	Редагування журналу аудиту	зменшити	Журнал аудиту лише на дописування (окремий сервіс, хеш-ланцюжок записів), журналювання переглядів і завантажень документів, копія журналу на окремий вузол	1.9 (низький)
Т-19	Файли-«бомби» в обробнику	зменшити	Обмеження розміру файлу й кількості сторінок, тайм-аут і ліміти cgroups для конвертера, окрема черга для великих файлів	4.3 (середній)
Т-20	Перевантаження запитами	прийняти	Залишається наявне базове обмеження частоти запитів (`limit_req` у Nginx). Обґрунтування — нижче	5.3 (середній)
Т-21	Виконання коду в конвертері	зменшити	Конвертер в окремому контейнері без мережі й без секретів (seccomp, read-only FS, непривілейований користувач), отримує файл і повертає результат через чергу; регулярне оновлення конвертера	5.0 (середній)
Т-22	Призначення ролей секретарем	усунути	Матриця делегування: секретар може призначати лише ролі «викладач» і «здобувач»; роль «завідувач» — лише адміністратор за підтвердженням другої особи	3.3 (низький)

Обґрунтування прийнятого ризику Т-20. Наслідок атаки — тимчасова недоступність без втрати чи розкриття даних (C:N, I:N, A:L). Строки подання заяв можуть бути продовжені наказом, а від атак на рівні каналу кафедру вже захищає мережа університету. Комерційний захист від DDoS коштує більше за очікувані збитки, тому ризик прийнято з наявним обмеженням частоти запитів у Nginx; залишковий ризик дорівнює вихідному (5,3).

Ризик Т-11 передано провайдеру за договором із додатковим шифруванням копій. Відповідність контрзаходів гілкам дерева атак наведено в табл. 4.4.

Таблиця 4.4 – Перекриття гілок дерева атак контрзаходами

Гілка дерева	Контрзахід, що її перекриває	Загрози реєстру
1 — прямий доступ до REST API	автентифікація і TLS в OpenSearch, видалення `location` з P1, мережеве правило	Т-01

Гілка дерева	Контрзахід, що її перекриває	Загрози реєстру
2 — збирання фрагментів через пошук	ACL-фільтр у запиті до індексу, без highlight для недоступних	T-03
3 — знімок індексу	шифрування резервних копій, ключ у сховищі секретів; API `_snapshot` лише для ролі адміністратора	T-11, T-01
4 — викрадені облікові дані	вимкнений режим налагодження, ізоляція конвертера без секретів, сховище секретів	T-08, T-21, T-12
усі гілки 1–4	**мінімізація індексу: для документів обмеженого доступу в D3 потрапляють лише метадані (назва, номер, дата), повний текст — ні**	T-01, T-03, T-11

5 АНАЛІЗ РЕЗУЛЬТАТІВ

5.1 Розподіл загроз за категоріями STRIDE

Гіпотеза підтвердилася: пріоритетна категорія варіанта — розкриття інформації — дала 12 загроз із 22 (55 %), тоді як кожна інша категорія — по 2. Причин дві. Перша — природа системи: головний актив СЕД (документи обмеженого доступу, К = В) існує щонайменше в п’яти копіях: оригінали в D2, повний текст в індексі D3, резервні копії D5, листи-сповіщення і журнали D4; кожна копія — окремий канал витоку. Друга — структура методу: категорія I застосовна до процесів, сховищ і потоків, а СЕД має п’ять сховищ і 17 потоків.

Водночас середня оцінка загроз категорії I (5,86) нижча, ніж у категорій S (7,20) та E (7,50). Більшість загроз розкриття впливають лише на конфіденційність, а для S:U і впливу лише C:H формула CVSS обмежує оцінку значенням 7,5. Тому за кількістю домінує категорія I, а за середньою вагою — S і E, загрози яких одразу зачіпають кілька властивостей.

5.2 Найвразливіші елементи діаграми

Найбільше загроз породив застосунок P2 (5 загроз), далі — обробник P3 (3). P2 — центральний процес, у який входить або з якого виходить сім потоків, що перетинають межі довіри (F3/F4 з DMZ, F6 до SSO, F7, F8, F10, F15 до зони даних); саме в ньому мають виконуватися всі перевірки прав, тож кожна пропущена перевірка — окрема загроза. P3 обробляє недовірені файли користувачів, тому зібрав загрози D та E. Сховища зони даних (D1–D5) разом мають 7 загроз, хоча

вони за найглибшою межею: загрози виникають там, де потік оминає точку контролю (F9 — pre-signed URL напряму до D2, проксіювання /search-api/ до D3). Тобто вразливість визначається не глибиною розташування елемента, а наявністю потоку, що перетинає межу без перевірки.

5.3 Чому T-01 отримала найвищу оцінку

T-01 має максимально можливу підоцінку експлуатованості для S:U: 8,22 × 0,85 (AV:N) × 0,77 (AC:L) × 0,85 (PR:N) × 0,85 (UI:N) = 3,887. Найбільший внесок дає PR:N: та сама загроза з PR:L мала б 7,6, тобто відсутність автентифікації додає 1,0 бала. Вплив C:H (вага 0,56) формує основну частину підоцінки впливу; додаткові I:L/A:L піднімають оцінку з 7,5 (як у T-04, де лише C:H) до 8,6. T-21 (8,5) має змінену область і повний вплив C:H/I:H/A:H, але потребує облікового запису (PR:L) і складної експлуатації (AC:H), тому поступається T-01 на 0,1.

5.4 Найефективніший контрзахід

Мінімізація пошукового індексу (для документів обмеженого доступу індексувати лише назву, номер і дату) перекриває всі чотири гілки дерева атак, а також загрози T-03 і T-11: у який би спосіб порушник не дістався до індексу чи його знімка, повного тексту там немає. Точкові заходи (автентифікація в OpenSearch, ACL-фільтр у запиті, шифрування знімків) закривають кожен по одній гілці, а оскільки корінь — вузол OR, пропуск будь-якого з них лишає мету досяжною. Серед загроз реєстру найбільше покриває централізована перевірка прав на об’єкт у P2 (T-02, T-03, T-05, T-22).

5.5 Прийняті ризики

Стратегію «прийняти» обрано лише для T-20 (CVSS 5,3): збиток обмежений тимчасовою недоступністю, строки можна продовжити, а спеціалізований захист від DDoS коштує більше за можливі втрати. Для загроз конфіденційності прийняття не розглядалося: витік персональних даних чи наказу незворотний, тож середніми після контрзаходів лишилися тільки T-19 (4,3) і T-21 (5,0), що стосуються доступності та ізольованого обробника.

6 ВИСНОВКИ

1) Для СЕД кафедри виявлено 9 активів, побудовано DFD (5 сутностей, 4 процеси, 5 сховищ, 17 потоків, 6 зон довіри) і методом STRIDE-per-element знайдено 22 загрози, з них 12 — розкриття інформації (55 %).
2) Чотири загрози мають високий ризик за CVSS: T-01 (8,6), T-21 (8,5), T-13 (7,6), T-04 (7,5); ще одна, T-02 (IDOR, 6,5), — за матрицею «ймовірність × вплив». Найкритичніша T-01 — відкритий API пошукового індексу: вона не потребує автентифікації (PR:N) і розкриває повний текст усіх документів.
3) Дерево атак для T-01 має чотири альтернативні гілки; найдешевша — прямий запит до API через шлях, видимий у фронтенді. Одним заходом усі гілки перекриває мінімізація індексу: повний текст документів обмеженого доступу не індексується.
4) Найбільший ефект за найменших витрат дають три заходи: мінімізація індексу (T-01, T-03, T-11), автентифікація й шифрування внутрішніх з'єднань (T-01, T-04, T-07) і централізована перевірка прав на об'єкт у P2 (T-02, T-03, T-05, T-22). T-01, T-04 і T-08 усуваються лише зміною конфігурації, тому їх слід виправити першочергово.
5) Після впровадження контрзаходів середня базова оцінка знижується з 6,00 до 3,10, жодна загроза не лишається високого рівня; ризик T-20 прийнято, ризик T-11 передано провайдеру з додатковим шифруванням.

7 ВІДОМОСТІ ПРО ВИКОРИСТАННЯ ГЕНЕРАТИВНИХ ІНСТРУМЕНТІВ

Під час виконання роботи як допоміжний засіб використано генеративну модель Claude (Anthropic): для складання чернетки переліку загроз і контрзаходів, підготовки скрипта scoring.py, опису діаграм у нотації Mermaid та оформлення звіту. Усі вектори CVSS обчислено наданим калькулятором cvss.py, оцінку найкритичнішої загрози перевірено вручну (підрозділ 4.2); прийняті рішення здобувач перевірив і може пояснити під час захисту.

ПЕРЕЛІК ПОСИЛАНЬ

1) Shostack A. Threat Modeling: Designing for Security. – Indianapolis : Wiley, 2014. – 624 p.
2) Common Vulnerability Scoring System v3.1: Specification Document / FIRST [Електронний ресурс]. – Режим доступу: https://www.first.org/cvss/v3.1/specification-document
3) CWE – Common Weakness Enumeration / MITRE [Електронний ресурс]. – Режим доступу: https://cwe.mitre.org/
4) CAPEC – Common Attack Pattern Enumeration and Classification / MITRE [Електронний ресурс]. – Режим доступу: https://capec.mitre.org/
5) OWASP Top 10:2021 [Електронний ресурс] / OWASP Foundation. – Режим доступу: https://owasp.org/Top10/
6) OWASP Application Security Verification Standard 4.0.3 [Електронний ресурс] / OWASP Foundation. – Режим доступу: https://owasp.org/www-project-application-security-verification-standard/
7) Anderson R. Security Engineering: A Guide to Building Dependable Distributed Systems. – 3rd ed. – Indianapolis : Wiley, 2020. – 1232 p.
8) Безпека програмного забезпечення. Частина 2. Лабораторний практикум / В. В. Соколовський. – Київ : КПІ ім. Ігоря Сікорського, 2026.

ДОДАТОК А

Репозиторій і артефакти роботи

Репозиторій: https://github.com/ip34is/7-sem (папка SoS)

Коміт, що відповідає зданій роботі:

`295121bb0e4b03f93d65ead1a1a1693054e61a43`

Стан роботи на цьому коміті: https://github.com/ip34is/7-sem/tree/295121bb0e4b03f93d65ead1a1a1693054e61a43/SoS

Артефакти (каталог звіт_лр1): threat_model.md — модель загроз (розділи 1–7); dfd.mmd і dfd.png — діаграма потоків даних; attack_tree.mmd і attack_tree.png — дерево атак; scoring_output.txt — вивід scoring.py. Допоміжний файл оцінювання — lab01_threat_model/scoring.py.

Відтворення результатів (з папки SoS):

```
python -m common.variants 14 --lab 1
cd lab01_threat_model
python cvss.py "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"   # 9.8
python scoring.py
python scoring.py --md
```

ДОДАТОК Б

Вивід програми scoring.py

```
ID   Ел.   S Вектор CVSS                              Бал Рівень    Зал. Ранг
T-01 D3    I AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L  8.6 високий    2.0    1 *
T-02 P2    I AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N  6.5 середній   3.1    6
T-03 P2    I AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N  4.3 середній   3.1   20
T-04 D2    I AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N  7.5 високий    2.2    4 *
T-05 F2    I AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N  5.3 середній   3.1   14
T-06 F14   I AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N  5.9 середній   3.7   11
T-07 F3/F4 I AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N  5.9 середній   2.0   12
T-08 P2    I AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N  5.3 середній   3.7   15
T-09 P3    I AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N  4.3 середній   3.1   21
T-10 D4    I AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N  4.4 середній   1.9   19
T-11 D5    I AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N  5.9 середній   2.2   13
T-12 D1    I AV:A/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N  6.4 середній   3.1   10
T-13 E1    S AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N  7.6 високий    3.7    3 *
T-14 E4    S AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N  6.8 середній   3.1    5
T-15 D2    T AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N  4.9 середній   2.2   17
T-16 P2    T AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N  6.5 середній   3.1    7
T-17 E1    R AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N  4.3 середній   3.1   22
T-18 D4    R AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N  4.9 середній   1.9   18
T-19 P3    D AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H  6.5 середній   4.3    8
T-20 F1    D AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L  5.3 середній   5.3   16
T-21 P3    E AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H  8.5 високий    5.0    2 *
T-22 P2    E AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N  6.5 середній   3.3    9
* — загроза високого ризику (CVSS ≥ 7.0); Зал. — оцінка після контрзаходу


Загрози за категоріями STRIDE (кількість, середня оцінка):
  S Spoofing                 2  7.20  ##
  T Tampering                2  5.70  ##
  R Repudiation              2  4.60  ##
  I Information disclosure  12  5.86  ############
  D Denial of service        2  5.90  ##
  E Elevation of privilege   2  7.50  ##
Загрози за елементами DFD:
  P2: 5, P3: 3, D2: 2, D4: 2, E1: 2, D3: 1, F2: 1, F14: 1, F3/F4: 1, D5: 1, D1:
1, E4: 1, F1: 1
Середня базова оцінка: 6.00 → після контрзаходів: 3.10
Загрози високого ризику (CVSS ≥ 7.0):
  T-01 (8.6), T-21 (8.5), T-13 (7.6), T-04 (7.5)
Найкритичніша загроза: T-01 (8.6)
  Відкритий REST API пошукового індексу з повними текстами


Самоперевірка:
  [OK] загроз не менше 12
  [OK] загроз високого ризику не менше 3
  [OK] охоплено щонайменше 3 категорії STRIDE
  [OK] пріоритетна категорія I переважає
  [OK] залишкова оцінка не перевищує вихідну
  [OK] контрольний вектор дає 9.8
```

ДОДАТОК В

Дерево атак для загрози T-01 у текстовому поданні

```
Мета (T-01): отримати повні тексти документів обмеженого доступу з індексу D3
  OR
  ├── 1. Прямий доступ до REST API OpenSearch
  │     AND
  │     ├── 1.1 Знайти доступний ендпойнт
  │     │     OR
  │     │     ├── 1.1.1 Просканувати IP-адресу кафедри на порт 9200/TCP
  │     │     └── 1.1.2 Знайти в JS-бандлі шлях /search-api/, що P1 веде до D3
  │     ├── 1.2 GET /_cat/indices без облікових даних (security plugin вимкнено)
  │     └── 1.3 Вивантажити індекс docs: _search?scroll=5m&size=10000
  ├── 2. Зібрати фрагменти через пошук застосунку P2 (T-03)
  │     AND
  │     ├── 2.1 Увійти через SSO обліковим записом будь-якого здобувача
  │     ├── 2.2 Шукати «наказ відрахування», ПІБ, номери наказів з highlight
  │     └── 2.3 Склеїти фрагменти, до яких ACL не застосовано
  ├── 3. Отримати знімок індексу (T-11)
  │     OR
  │     ├── 3.1 Завантажити snapshot із D5 ключем, викраденим із cron-скрипта P4
  │     └── 3.2 Через відкритий API створити власний _snapshot-репозиторій
  └── 4. Підключитися до D3 з викраденими обліковими даними
        AND
        ├── 4.1 Отримати облікові дані OpenSearch
        │     OR
        │     ├── 4.1.1 Прочитати змінні оточення на сторінці помилки (T-08)
        │     └── 4.1.2 Виконати код у P3 шкідливим DOCX (T-21), прочитати .env
        └── 4.2 Надіслати запити до D3 зі скомпрометованого внутрішнього вузла
```

ДОДАТОК Г

Лістинг файла lab01_threat_model/scoring.py

```
"""scoring.py — оцінювання переліку загроз за CVSS v3.1 (ЛР1, варіант 14).

Система: електронний документообіг кафедри (СЕД).
Пріоритетна категорія STRIDE: розкриття інформації (Information disclosure).

Для кожної загрози задано:
  - елемент DFD (див. звіт_лр1/dfd.mmd) і категорію STRIDE;
  - вектор CVSS до впровадження контрзаходу (vector);
  - вектор після впровадження контрзаходу з реєстру ризиків (residual);
  - експертні ймовірність і вплив (H/C/B) для матриці «ймовірність × вплив».

Запуск (з каталогу lab01_threat_model):
  python scoring.py          # таблиця оцінок і зведена статистика
  python scoring.py --md     # таблиця розділу 4 у форматі Markdown
"""
from __future__ import annotations

import sys
from collections import Counter

from cvss import base_score

MIN_THREATS = 12
MIN_HIGH_RISK = 3
HIGH_RISK = 7.0
FOCUS = "I"

STRIDE = {
    "S": "Spoofing",
    "T": "Tampering",
    "R": "Repudiation",
    "I": "Information disclosure",
```

```
    "D": "Denial of service",
    "E": "Elevation of privilege",
}

# (id, елемент DFD, STRIDE, коротка назва, вектор, залишковий вектор, ймовірність, вплив)
THREATS = [
    ("T-01", "D3", "I", "Відкритий REST API пошукового індексу з повними текстами",
     "AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L", "AV:A/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N", "B", "B"),
    ("T-02", "P2", "I", "IDOR під час завантаження файлу документа",
     "AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N", "AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N", "B", "B"),
    ("T-03", "P2", "I", "Фрагменти й кількість збігів недоступних документів у пошуку",
     "AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N", "AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N", "C", "C"),
    ("T-04", "D2", "I", "Анонімний доступ до бакета документів у MinIO",
     "AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N", "AV:N/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N", "C", "B"),
    ("T-05", "F2", "I", "Витік довгоживучих pre-signed URL",
     "AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N", "AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N", "C", "C"),
    ("T-06", "F14", "I", "Вміст документів у листах-сповіщеннях",
     "AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N", "AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N", "C", "C"),
    ("T-07", "F3/F4", "I", "Перехоплення нешифрованого трафіку P1↔P2",
     "AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N", "AV:A/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N", "H", "B"),
    ("T-08", "P2", "I", "Детальні повідомлення про помилки (режим налагодження)",
     "AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N", "AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N", "B", "H"),
    ("T-09", "P3", "I", "Приховані метадані та «зафарбований» текст в опублікованих файлах",
     "AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N", "AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N", "C", "C"),
    ("T-10", "D4", "I", "Токени сесій і персональні дані в журналах",
     "AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N", "AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N", "H", "C"),
    ("T-11", "D5", "I", "Нешифровані резервні копії у хмарі",
     "AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N", "AV:N/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N", "H", "B"),
    ("T-12", "D1", "I", "Обліковий запис застосунку в БД — суперкористувач, пароль у .env",
     "AV:A/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N", "AV:A/AC:H/PR:H/UI:N/S:U/C:L/I:L/A:N", "H", "B"),
    ("T-13", "E1", "S", "Викрадення сесії завідувача через збережений XSS",
     "AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N", "AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:N", "C", "B"),
    ("T-14", "E4", "S", "Підстановка ID-токена, виданого іншому клієнту SSO",
     "AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N", "AV:N/AC:H/PR:H/UI:R/S:U/C:L/I:L/A:N", "H", "B"),
    ("T-15", "D2", "T", "Заміна файлу вже підписаного документа",
     "AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N", "AV:N/AC:H/PR:H/UI:N/S:U/C:N/I:L/A:N", "H", "B"),
    ("T-16", "P2", "T", "CSRF на погодження документа",
     "AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N", "AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:L/A:N", "C", "C"),
    ("T-17", "E1", "R", "Заперечення факту погодження документа",
     "AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N", "AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:N", "C", "C"),
    ("T-18", "D4", "R", "Редагування журналу аудиту; перегляди не журналюються",
     "AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N", "AV:L/AC:H/PR:H/UI:N/S:U/C:N/I:L/A:N", "H", "C"),
```

```
    ("T-19", "P3", "D", "Файли-«бомби» виснажують обробник",
     "AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H", "AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L", "C", "C"),
    ("T-20", "F1", "D", "Перевантаження запитами в пікові періоди",
     "AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L", "AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L", "C", "H"),
    ("T-21", "P3", "E", "Виконання коду через вразливість конвертера документів",
     "AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H", "AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L", "C", "B"),
    ("T-22", "P2", "E", "Секретар призначає будь-які ролі, зокрема «завідувач»",
     "AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N", "AV:N/AC:H/PR:H/UI:N/S:U/C:L/I:L/A:N", "H", "B"),
]

LEVEL_POINTS = {"H": 1, "C": 2, "B": 3}


def severity(score: float) -> str:
    """Якісний рівень за таблицею 2.3 практикуму."""
    if score == 0.0:
        return "немає"
    if score < 4.0:
        return "низький"
    if score < 7.0:
        return "середній"
    if score < 9.0:
        return "високий"
    return "критичний"


def matrix_level(likelihood: str, impact: str) -> str:
    """Матриця 3×3 «ймовірність × вплив»: добуток балів 1–2 / 3–4 / 6–9."""
    product = LEVEL_POINTS[likelihood] * LEVEL_POINTS[impact]
    if product >= 6:
        return "високий"
    if product >= 3:
        return "середній"
    return "низький"


def score(vector: str) -> float:
    return base_score("CVSS:3.1/" + vector)
```

```
def evaluate() -> list[dict]:
    rows = []
    for tid, element, cat, title, vector, residual, lik, imp in THREATS:
        rows.append({
            "id": tid, "element": element, "cat": cat, "title": title,
            "vector": vector, "score": score(vector),
            "residual": residual, "residual_score": score(residual),
            "lik": lik, "imp": imp, "matrix": matrix_level(lik, imp),
        })
    # Ранг: спершу за базовою оцінкою, за рівних — за матрицею, далі за номером.
    order = sorted(rows, key=lambda r: (-r["score"],
                                        -LEVEL_POINTS[r["lik"]] * LEVEL_POINTS[r["imp"]],
                                        r["id"]))
    for rank, r in enumerate(order, start=1):
        r["rank"] = rank
    return rows



def print_table(rows: list[dict]) -> None:
    print(f"{'ID':4} {'Ел.':5} S {'Вектор CVSS':35} {'Бал':>4} {'Рівень':9} "
          f"{'Зал.':>4} {'Ранг':>4}")
    for r in rows:
        mark = " *" if r["score"] >= HIGH_RISK else ""
        print(f"{r['id']:4} {r['element']:5} {r['cat']} {r['vector']:35} "
              f"{r['score']:4.1f} {severity(r['score']):9} {r['residual_score']:4.1f} "
              f"{r['rank']:4}{mark}")
    print("* — загроза високого ризику (CVSS ≥ 7.0); Зал. — оцінка після контрзаходу")



def print_markdown(rows: list[dict]) -> None:
    print("| № загрози | Вектор CVSS | Базова оцінка | Імовірність | Вплив | Ранг ризику |")
    print("|-----------|-------------|---------------|-------------|-------|-------------|")
    for r in rows:
        s = f"{r['score']:.1f}"
        if r["score"] >= HIGH_RISK:
            s = f"**{s}**"
        print(f"| {r['id']} | `CVSS:3.1/{r['vector']}` | {s} ({severity(r['score'])}) | "
              f"{r['lik']} | {r['imp']} | {r['rank']} — {r['matrix']} |")
```

```
def print_summary(rows: list[dict]) -> bool:
    by_cat = Counter(r["cat"] for r in rows)
    by_elem = Counter(r["element"] for r in rows)
    high = [r for r in rows if r["score"] >= HIGH_RISK]
    top = min(rows, key=lambda r: r["rank"])

    print("\nЗагрози за категоріями STRIDE (кількість, середня оцінка):")
    for c in STRIDE:
        scores = [r["score"] for r in rows if r["cat"] == c]
        avg = sum(scores) / len(scores) if scores else 0.0
        print(f"  {c} {STRIDE[c]:23} {by_cat[c]:2}  {avg:4.2f}  {'#' * by_cat[c]}")
    print("Загрози за елементами DFD:\n  " +
          ", ".join(f"{e}: {n}" for e, n in by_elem.most_common()))
    print(f"Середня базова оцінка: {sum(r['score'] for r in rows) / len(rows):.2f} → "
          f"після контрзаходів: {sum(r['residual_score'] for r in rows) / len(rows):.2f}")
    print("Загрози високого ризику (CVSS ≥ 7.0):\n  " +
          ", ".join(f"{r['id']} ({r['score']})" for r in sorted(high, key=lambda r: r["rank"])))
    print(f"Найкритичніша загроза: {top['id']} ({top['score']})\n  {top['title']}")

    focus_ok = all(by_cat[FOCUS] > n for c, n in by_cat.items() if c != FOCUS)
    checks = {
        f"загроз не менше {MIN_THREATS}": len(rows) >= MIN_THREATS,
        f"загроз високого ризику не менше {MIN_HIGH_RISK}": len(high) >= MIN_HIGH_RISK,
        "охоплено щонайменше 3 категорії STRIDE": len(by_cat) >= 3,
        f"пріоритетна категорія {FOCUS} переважає": focus_ok,
        "залишкова оцінка не перевищує вихідну": all(r["residual_score"] <= r["score"] for r in rows),
        "контрольний вектор дає 9.8": base_score("CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H") == 9.8,
    }
    print("\nСамоперевірка:")
    for name, ok in checks.items():
        print(f"  [{'OK' if ok else '!!'}] {name}")
    return all(checks.values())



if __name__ == "__main__":
    sys.stdout.reconfigure(encoding="utf-8")
    results = evaluate()
    if "--md" in sys.argv:
        print_markdown(results)
```

```
else:
    print_table(results)
    sys.exit(0 if print_summary(results) else 1)
```